DOMAIN 1 // ENGAGEMENT MANAGEMENT

COMPTIA PENTEST+ PT0-003 · OBJECTIVES V3.0 · ONE-PAGE REFERENCE

13% OF EXAM · ~11–12 QUESTIONS

TEN REFLEXES

- MSA is the umbrella; SoW is the individual engagement under it.
- RoE has exactly four parts: exclusions, test cases, escalation process, testing window.
- Anything outside written authorization → stop, preserve, escalate immediately.
- Anything that changes scope, cost, or timeline → written amendment, authorized signer.
- Severity is technical, impact is business, risk is likelihood × impact.
- CREST is an accreditation body, not a methodology.
- STRIDE finds threats, DREAD rates them, OCTAVE assesses the organization.
- Detailed findings are a catalog; the attack narrative is the chain.
- RBAC and minimum password requirements are administrative; user training is operational.
- A recurring vulnerability calls for process-level remediation, not another patch.

1.1 PRE-ENGAGEMENT SUMMARIZE

- **NDA** — confidentiality, signed earliest, often mutual
- **MSA** — relationship terms: liability, payment, IP ownership
- **SoW** — this job: deliverables, milestones, timeline, cost
- **ToS** — Terms of *Service* (CompTIA's wording)
- **Authorization letter** — filed under legal/ethical, not agreements. Signed by someone with authority; carried on your person.

SoW = what & how much | RoE = how, when, how far

- **RoE:** exclusions · test cases · escalation process · testing window
- **Regs/frameworks/standards** split two ways only: *privacy* | *security*
- **Target selection:** CIDR ranges · domains · IP addresses · URLs
- **Assessment types:** web · network · mobile · cloud · API · application · wireless
- **Shared responsibility:** hosting provider · customer · tester · third party
- **Legal & ethical:** authorization letters · mandatory reporting · risk to the tester

IaaS = most customer responsibility · SaaS = least. A client cannot authorize an asset it does not own.

1.2 COLLABORATION EXPLAIN

Nine bullets: peer review · stakeholder alignment · root cause analysis · escalation path · secure distribution · articulation of risk, severity, impact · goal reprioritization · business impact analysis · client acceptance

- **Escalation triggers:** critical finding · indicators of prior compromise · criminal activity · damage caused by testing · out-of-scope discovery
- **Response:** stop · preserve · notify. Never remediate, never keep exploiting, never save it for the report.
- **RCA** looks backward at why the flaw exists; **BIA** looks forward at what it costs
- **Peer review** = internal, before delivery · **Client acceptance** = client sign-off, after
- **Goal reprioritization** needs client agreement, plus an amendment if scope/cost/timeline shift
- **Secure distribution:** encrypt · password out of band · need-to-know list agreed in advance · classification markings · retention & destruction

Audience: executives → business risk and cost · technical staff → vector, steps, remediation · third parties → scoped extract only

1.3 FRAMEWORKS COMPARE

- **OSSTMM** — metrics-driven, RAV scoring, five channels incl. human & physical
- **PTES** — seven phases, pre-engagement through reporting
- **CREST** — accredits firms and testers; not a methodology
- **MITRE ATT&CK** — tactics = objective, techniques = method
- **OWASP Top 10** — awareness document, not a test process
- **MASVS** — mobile application verification standard
- **Purdue** — L0–L5, L3.5 = industrial DMZ; L0/L1 carry physical safety risk
- **DREAD** — damage, reproducibility, exploitability, affected users, discoverability → rates and ranks
- **OCTAVE** — organizational, asset-driven, *self-directed* by the org's own staff

STRIDE → property violated

Spoofing	Authentication
Tampering	Integrity
Repudiation	Non-repudiation
Info disclosure	Confidentiality
Denial of service	Availability
Elev. of privilege	Authorization

NOT on the PT0-003 list: ISSAF · NIST SP 800-115 · OWASP WSTG · OWASP FSTM

1.4 REPORT COMPONENTS EXPLAIN

- **Five components:** executive summary · methodology · detailed findings · attack narrative · recommendations (remediation guidance)
- **Executive summary** — non-technical, business risk, stands alone
- **Attack narrative** — chronological chain; why three mediums equal one critical
- **Format alignment** = what it looks like · **Documentation specifications** = what it must contain and to what evidentiary standard
- **Risk scoring:** CVSS base = intrinsic · temporal = exploit maturity · environmental = client's deployment. EPSS = likelihood, not severity.
- **Definitions** — the glossary that prevents severity disputes
- **Limitations** = what constrained you · **assumptions** = what you took on faith
- **Reporting considerations:** legal · ethical · QC · AI
- **QC** is the umbrella; peer review is a technique inside it
- **AI** — never submit client data to third-party services · verify all output · check contractual and disclosure obligations

A pentest is a point-in-time sample. Absence of a finding is not absence of vulnerability.

1.5 REMEDIATION GIVEN A SCENARIO

Technical = enforced by a machine | **Administrative** = written down as policy | **Operational** = people on a schedule | **Physical** = you can touch it

- SQL / command injection, XSS → **Sanitize input, parameterize queries**
- Cleartext credentials or data → **Encryption**
- Password spraying, no second factor → **Multifactor authentication**
- Missing security updates, known CVEs → **Patch management**
- Same vulnerability keeps returning → **Process-level remediation**
- Hardcoded credentials in source/config → **Secrets management solution**
- Exposed or never-rotated key → **Key rotation, then secrets mgmt**
- Expired or self-signed certificate → **Certificate management**
- Default accounts, legacy protocols → **System hardening**
- Flat network, IT/OT convergence → **Network segmentation**
- Excessive privilege, privilege creep → **Role-based access control**
- Vulnerabilities recur each release → **Secure SDLC**
- Weak or cracked passwords → **Minimum password requirements**
- No defined process, orphaned accounts → **Policies and procedures**
- Phishing / USB drop success → **User training**
- Credentials used at 03:00 → **Time-of-day restrictions**
- Unmonitored process, long-tenured admin → **Mandatory vacations · job rotation**
- Tailgating into the facility → **Access control vestibule**
- Cloned badge granted entry → **Biometric controls**
- No record of after-hours entry → **Video surveillance (detective only)**

THE THREE CLASSIFICATION TRAPS

Role-based access control is *administrative*, not technical. Minimum password requirements are *administrative*, not technical. User training is *operational*, not administrative.

A WAF against an injection finding is a compensating control, not a remediation. Segmentation limits blast radius; it does not fix the vulnerability.

Anything exceptional → escalate immediately. // Anything that changes → document in writing.